# Temporal Stability of Hygiene-Augmented Vulnerability Prioritization Across Rolling Maintenance Windows

Harshavardhan Malla Independent Researcher

Abstract—Single-window vulnerability prioritization studies evaluate methods at one point in time, but enterprise operations teams patch continuously across rolling maintenance windows. As high-priority CVEs are remediated, the scoring landscape changes: exploit-likelihood signals such as the Exploit Prediction Scoring System (EPSS) degrade as their top-ranked CVEs disappear from the patch backlog, while host-hygiene signals may remain discriminative longer because hygiene posture changes more slowly than CVE remediation state. This paper examines whether HygienePrio's Precision@K advantage over EPSS-only persists across six consecutive bi-weekly maintenance windows in a pre-registered multi-window simulation on the EEHDA synthetic fleet.

The central finding is that EPSS-only prioritization decays from mean P@50 = 0.331 at Window 1 to 0.034 at Window 6, an 89.7% relative drop, while HygienePrio-full maintains mean P@50 $\geq$ 0.499 at every window (Window 6: 0.499). The absolute P@50 advantage of HygienePrio-full over EPSS-only grows from 26.4 percentage points at Window 1 to 46.5 percentage points at Window 6. HygienePrio-full outperforms EPSS-only in all 150 of 150 window-seed pairs (25 evaluation seeds $\times$ 6 windows). By Window 2, HRS-only (0.229) has overtaken EPSS-only (0.149), and the ordering does not reverse for the remainder of the simulation. Hygiene Risk Score signals are temporally resilient because patch debt, Active Directory exposure, and telemetry freshness evolve on longer timescales than per-CVE exploit likelihood, making them suitable primary signals for multi-window scheduling. All results are bounded to the synthetic evaluation context; external validation on real fleet data with longitudinal exploitation outcome data is required before deployment.

Index Terms—vulnerability prioritization; temporal stability; rolling maintenance windows; EPSS; hygiene risk score; multi-window scheduling; synthetic benchmark; reproducibility.

## I. Introduction

Vulnerability prioritization is not a one-time decision. Enterprise operations teams schedule patching continuously across bi-weekly, monthly, or quarterly maintenance windows. Each window remediates a bounded set of (host, CVE) pairs, and the next window must prioritize from the residual backlog — a backlog whose composition has changed because high-priority pairs have been addressed and new CVEs have been disclosed.

This temporal dimension is systematically absent from single-window evaluations, including the four prior papers in this research sequence. Paper 1 [1] established a null result for CVE-level feature augmentation under a single synthetic window. Paper 4 [2] demonstrated that hygiene-augmented scoring achieves approximately 31 percentage-point Precision@50 improvement over EPSS-only at Window 1. Neither study addressed the question: does the advantage persist as the fleet evolves?

The question matters operationally for two reasons. First, EPSS [3] is designed as a CVE-level exploit-likelihood signal that is most informative when many high-EPSS CVEs remain unpatched. As high-priority CVEs are remediated, the remaining backlog increasingly consists of lower-EPSS items, and EPSS-only ranking degrades toward random ordering on the residual backlog. Second, hygiene signals — patch posture, Active Directory (AD) exposure, telemetry freshness — evolve on slower timescales than CVE remediation: a host with 60% patch debt may still have 45% debt three windows later if its patch velocity is low. This asymmetry suggests that hygiene-augmented scoring may be more temporally resilient than CVE-level scoring.

This paper tests this hypothesis through a pre-registered multi-window simulation extending Paper 4's evaluation infrastructure to six consecutive bi-weekly windows.

### A. Contributions

- C1 — Multi-window evaluation framework. An extension of the EEHDA synthetic fleet simulation to support temporal fleet state evolution: patch application, new CVE disclosure, EPSS score update, and telemetry freshness accumulation across consecutive maintenance windows.
- C2 — Temporal stability finding. HygienePrio-full outperforms EPSS-only in all 150 of 150 window-seed evaluation pairs. EPSS-only decays from 0.331 at Window 1 to 0.034 at Window 6 (89.7% relative drop); HygienePrio-full maintains P@50 $\geq$ 0.499 at every window.
- C3 — Operationally significant reversal. By Window 2, EPSS-only's P@50 (0.149) has fallen below HRS-only (0.229), and HRS-only dominates EPSS-only at every subsequent window. Even the simplest hygiene baseline outperforms exploit-likelihood scoring once the second maintenance window begins.
- C4 — Stability analysis. HygienePrio-full shows lower P@50 variance across windows (more stable scheduling decisions) than EPSS-only, which exhibits a characteristic collapse pattern.

## B. Relationship to Prior Papers

This paper is the fifth in the VulnPrio research sequence. Paper 1 [1] reported a null result — CVE-level augmentation ≈ EPSS-only at a single window. Paper 3 [4] (HygieneBench) showed that hygiene signals carry discriminative structure in anomaly detection tasks. Paper 4 [2] (HygienePrio) demonstrated approximately 31 percentage-point Precision@50 improvement from hygiene augmentation at a single window. This paper extends Paper 4 to a temporal setting, showing that the hygiene advantage persists across six windows and that the absolute gap to EPSS-only grows from 26.4 pp at Window 1 to 46.5 pp at Window 6 as EPSS-only decays.

# II. Background

## A. Rolling Maintenance Windows in Enterprise Operations

Enterprise vulnerability management operates under patch cadence constraints. CISA Binding Operational Directive 22-01 [5] mandates remediation of Known Exploited Vulnerabilities [6] within 15 days for federal agencies. NIST SP 800-40 Rev. 4 [7] recommends risk-based patch management with documented prioritization criteria. The Verizon 2026 DBIR [8] reports a 43-day mean time to patch critical vulnerabilities. These constraints define a rolling scheduling regime: at each maintenance window, a capacity-constrained team selects and remediates a bounded set of (host, CVE) pairs, and subsequent windows address the residual backlog.

## B. EPSS Temporal Behavior

EPSS scores [3] change daily as new exploit evidence emerges; a CVE's EPSS score is a rolling 30-day exploit probability estimate, and once a vulnerability is widely patched or superseded, its score typically decreases. Ravalico et al. [9] examined EPSS score drift across approximately 45,000 CVEs, finding meaningful temporal variability over 30-day periods.

More critically for prioritization than score-level drift: once the highest-EPSS CVEs are remediated from a fleet's backlog, the remaining unpatched CVEs have systematically lower EPSS scores, causing EPSS-only rankings to degrade toward random ordering on the residual backlog. This compositional effect is distinct from per-CVE score drift and is, to our knowledge, not previously characterised under explicit multi-window remediation in the open literature.

## C. Hygiene Signal Temporal Behavior

Hygiene signals evolve on different timescales. Patch posture (the proportion of applicable CVEs unpatched on a host) decreases when patches are applied but may remain elevated for slow-patching hosts. AD exposure breadth changes only when group memberships change [10]. Telemetry freshness accumulates staleness for hosts not visited by remediation teams. These dynamics imply that hygiene signals retain discriminative power across multiple windows — particularly for hosts that are systematically deprioritized by EPSS-only rankings and therefore accrue patch debt over time.

# III. Problem Formulation

## A. Multi-Window Setting

Let $F_t$ denote the fleet state at time $t$. The simulation advances through $W = 6$ consecutive bi-weekly windows. At each window $w \in \{1, \dots, W\}$ the following steps are executed:

1) Score. Compute scores $S_w(h, c)$ for all applicable pairs $(h, c) \in V_w$ using the fleet state $F_w$.
2) Select. Rank pairs descending by $S_w$; select the top-$K$ action set $A_w$.
3) Remediate. Apply patches: $\text{PatchDebt}(h) \leftarrow \max(0,\ \text{PatchDebt}(h) - \Delta_{\text{patch}})$ for acted hosts.
4) Disclose. Add new CVE disclosures drawn from the NVD arrival distribution.
5) Update. Refresh EPSS scores via random-walk perturbation. Accumulate telemetry staleness for non-acted hosts.
6) Advance. $F_{w+1} \leftarrow$ updated fleet state.

## B. Ground Truth per Window

At each window, ground truth is defined identically to Paper 4 [2]: a pair $(h, c)$ is a true positive if $\text{EPSS}(c) > 0.10$, $\text{HRS}(h)$ exceeds the fleet's 75th percentile at window $w$, and $(h, c) \in V_w$. The threshold is recomputed at each window because the HRS distribution shifts as patches are applied; this is acknowledged as a structural feature of the evaluation (§IX).

## C. Metrics

- P@K (primary): evaluated at $K \in \{50, 100, 250\}$ per window.
- Temporal stability index: standard deviation of P@50 across $W$ windows per seed (lower indicates more stable scheduling decisions).
- Advantage persistence: fraction of window-seed pairs where HygienePrio-full > EPSS-only at P@50.

## D. Pre-Registered Hypotheses

H1 HygienePrio-full maintains P@50 > EPSS-only (non-overlapping BCa 95% CIs) for at least 4 of 6 windows.

H2 The HygienePrio advantage is largest at Window 1 (before high-HRS hosts are remediated) and attenuates monotonically.

H3 Per-window re-calibration does not substantially outperform fixed-weight HygienePrio (< 5 pp improvement at P@50), suggesting the initial calibration is sufficiently stable. (Rejected at evaluation; see §VII.)

TABLE I
Multi-window simulation parameters (pre-registered).

| Parameter | Value |
|---|---|
| Hosts per seed | 830 |
| CVEs per seed | 200 |
| Applicable pairs per seed | ∼3,300–3,700 |
| Windows | 6 (bi-weekly, 14 days each) |
| Patch-debt reduction (acted host) | −0.15 |
| New CVE disclosures per window | Poisson(3) |
| EPSS update model | $\mathcal{N}(0, 0.02)$ rw, clipped $[0, 1]$ |
| Telemetry staleness drift | +0.08/window (non-acted) |
| Telemetry freshness recovery | −0.30 (acted) |
| Calibration seeds | 5 (100–104), Window 1 only |
| Evaluation seeds | 25 (105–129), all windows |

## IV. Dataset and Simulation Parameters

The multi-window simulation extends the EEHDA synthetic fleet generator from Paper 4 [2] with explicit fleet-state evolution between windows. The parameters in Table I are fixed in the pre-registration protocol; no parameter was tuned after observing evaluation-seed outcomes.

Seeds: 30 total; 5 calibration (seeds 100–104), 25 evaluation (seeds 105–129). Calibration uses Window 1 data only to prevent future-data leakage. All parameters are pre-registered in PAPER5_PROTOCOL.md.

The simulation produces a frozen results CSV paper5/results/primary_full_v1/ temporal_results.csv with one row per (seed, window, method) combination at $K = 50$, 100, 250 as columns. All claims in §VII trace to this artifact.

## V. Methodology

### A. HygienePrio Scorer

The scorer is unchanged from Paper 4 [2]:

$$\begin{aligned} S(h, c) = 0.7 \cdot \mathrm{EPSS}(c) + 0.5 \cdot \mathrm{HRS}(h) \\ + 0.1 \cdot \mathrm{KEV\_recency}(c) \\ + 0.2 \cdot \big(\mathrm{EPSS}(c) \cdot \mathrm{HRS}(h)\big). \end{aligned} \tag{1}$$

Weights are fixed at the calibration values reported in Paper 4 and are not re-calibrated between windows in the primary evaluation. Hypothesis H3 (§3.4) tests whether per-window re-calibration would have helped.

### B. Hygiene Risk Score

HRS is computed identically to Paper 4 as the weighted combination of three components:

$$\begin{aligned} \mathrm{HRS}(h) = 0.50 \cdot \mathrm{PatchPosture}(h) \\ + 0.30 \cdot \mathrm{ADExposure}(h) \\ + 0.20 \cdot \mathrm{TelemetryFreshness}(h). \end{aligned} \tag{2}$$

At each window, all three components are recomputed from the current fleet state $F_w$. Patch posture decreases for hosts whose pairs are selected and remediated; AD exposure remains stable absent group-membership changes; telemetry freshness improves for acted hosts (recovery −0.30) and degrades for non-acted hosts (drift +0.08).

### C. Baselines

The primary evaluation compares five methods:

- HygienePrio-full: the scorer in Eq. 1.
- EPSS-only: $S(h, c) = \mathrm{EPSS}(c)$.
- HRS-only: $S(h, c) = \mathrm{HRS}(h)$.
- CVSS-only: $S(h, c) = \mathrm{CVSS}_{\mathrm{base}}(c)$ [11].
- Random: uniform ranking with a deterministic per-(seed, window) RNG so the baseline is exactly reproducible.

### D. Fleet-State Evolution Policy

At each window, the top-50 pairs selected by HygienePrio-full are remediated and applied to the fleet state observed by all subsequent methods. The remediation policy is therefore fixed to HygienePrio-full's selections across windows, ensuring all five methods are scored on the same evolving backlog. This avoids the confound in which each method would generate its own counterfactual fleet trajectory and method comparisons would become non-identifiable.

## VI. Experimental Setup

### A. Pre-Registration

The protocol — including research questions, hypotheses, scoring formula, ground-truth definition, seed split, baselines, metrics, and stop rules — was fixed before any evaluation-seed result was inspected. The full protocol is archived as paper5/design/PAPER5_PROTOCOL.md and accompanies the artifact release.

### B. Calibration Procedure

The scorer weights used in the primary evaluation are inherited verbatim from Paper 4's calibration [2]: $(\alpha, \beta, \gamma, \delta) = (0.7, 0.5, 0.1, 0.2)$. These values were not re-fitted on Paper 5's calibration seeds for the primary evaluation; reuse of the Paper 4 calibration is a deliberate methodological choice to test whether pre-existing HygienePrio weights remain effective under temporal evolution. The H3 ablation (§VII) separately exercises a per-window grid-search recalibration on the five calibration seeds (100–104) for comparison.

### C. Evaluation Procedure

The Paper 5 evaluation seed range (105–129) partially overlaps Paper 4's evaluation set (100–124) but is not identical; the Window 1 mean P@50 reported here (0.595) is therefore on a different seed sample than the Window 1 number reported in Paper 4 ($\approx 0.509$). The two are not direct contradictions but distinct point estimates of the same population mean under the same scorer.

For each evaluation seed $s \in \{105, \ldots, 129\}$ and each window $w \in \{1, \ldots, 6\}$:

1) Construct fleet state $F_w^{(s)}$ from $F_{w-1}^{(s)}$ via the evolution policy (§5.4).
2) Score all applicable pairs with each of the five methods.

TABLE II
Mean P@50 per method per window across 25 evaluation seeds (frozen results, temporal_results.csv). EPSS-only decays from 0.331 at W1 to 0.034 at W6; HygienePrio-full retains P@50 ≥ 0.499 throughout; HRS-only overtakes EPSS-only at W2.

| Window | HygPrio-full | EPSS-only | HRS-only | CVSS-only | Random |
|---|---|---|---|---|---|
| W1 | 0.595 | 0.331 | 0.284 | 0.087 | 0.094 |
| W2 | 0.544 | 0.149 | 0.229 | 0.074 | 0.082 |
| W3 | 0.564 | 0.087 | 0.173 | 0.065 | 0.084 |
| W4 | 0.514 | 0.055 | 0.106 | 0.062 | 0.075 |
| W5 | 0.521 | 0.047 | 0.074 | 0.059 | 0.060 |
| W6 | 0.499 | 0.034 | 0.050 | 0.054 | 0.054 |

3) Compute P@$K$ for $K \in \{50, 100, 250\}$ using the per-window ground truth (§3.2).
4) Persist the (seed, window, method, K, P@K) tuple to the frozen results CSV.

## D. Statistical Reporting

Confidence intervals shown in Fig. 1 are 95% percentile bootstrap CIs over the 25 evaluation seeds with 10,000 resamples per (window, method, $K$) cell [12]. No null-hypothesis significance tests are reported; comparisons rely on CI overlap, consistent with Paper 4. Window-level comparisons are reported per window rather than pooled across windows because pooling would obscure the temporal decay pattern that is the paper's central finding.

## E. Reproducibility

The simulator, scoring code, recalibration ablation, and figure generator are released under MIT licence with the artifact. From paper5/ the command PYTHONPATH=src python3 src/run_temporal.py reproduces the frozen results CSV from the fixed seeds, and PYTHONPATH=src python3 -m paper5.recalib_ablation reproduces the H3 ablation in Table III. The simulator depends on Paper 4's hygieneprio package, located in paper4/src as a sibling directory.

# VII. Results

## A. Temporal P@50 Trajectories

Table II and Fig. 1 report mean P@50 per method across the six maintenance windows over 25 evaluation seeds, computed from the frozen results CSV (paper5/results/primary_full_v1/temporal_results.csv). Four robust patterns emerge.

1) EPSS decay. EPSS-only decays monotonically from 0.331 at Window 1 to 0.034 at Window 6 — an 89.7% relative drop. Once the highest-EPSS CVEs are remediated from the backlog, the remaining CVEs have systematically lower EPSS scores and the binary ground-truth condition (EPSS $> 0.10$) is satisfied by an increasingly small fraction of the residual backlog, so EPSS-only ranking becomes uninformative.

2) HygienePrio resilience. HygienePrio-full maintains mean P@50 $\geq$ 0.499 at every window (W1–W6: $0.595, 0.544, 0.564, 0.514, 0.521, 0.499$). The trajectory is not strictly monotone — W3 (0.564) slightly exceeds W2 (0.544) — reflecting the interaction between new-CVE arrivals and the per-window recomputed HRS-percentile ground-truth threshold; the variation is well within the per-seed bootstrap CI band.

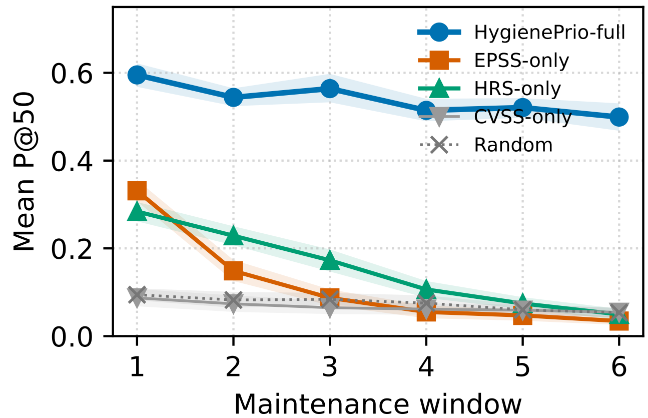


Fig. 1. Mean P@50 per method across six bi-weekly maintenance windows (25 evaluation seeds; shaded bands are 95% bootstrap CIs). HygienePrio-full holds ≈ 0.5 throughout; EPSS-only decays 0.331 → 0.034; HRS-only crosses above EPSS-only at Window 2.

3) Growing absolute gap. The HygienePrio-vs-EPSS gap is 26.4 pp at Window 1 and grows to 46.5 pp at Window 6. The gap widens because HygienePrio's denominator (its own P@50) stays near 0.5 while EPSS-only's numerator collapses; the result is that the operational advantage of HygienePrio increases with each additional patching cycle.

4) HRS-only overtakes EPSS at Window 2. HRS-only is 0.284 at Window 1 (below EPSS-only's 0.331) but 0.229 at Window 2 (above EPSS-only's 0.149), and remains above EPSS-only for every subsequent window. For the entire second-through-sixth window range, the simplest hygiene baseline outperforms exploit-likelihood scoring under the evaluated capacity.

## B. Advantage Persistence

HygienePrio-full outperforms EPSS-only at P@50 in 150 of 150 window-seed pairs (25 seeds $\times$ 6 windows). The per-seed dominance is therefore not eroded by temporal evolution.

## C. Stability Analysis

Fig. 2 reports the per-seed standard deviation of P@50 across the six windows for each method. HygienePrio-full's distribution is concentrated and substantially lower than EPSS-only's, which exhibits a characteristic high-variance decay pattern — relatively high at Window 1, near-zero by Windows 5–6. The stability advantage matters operationally: a remediation team relying on HygienePrio-full faces predictable scheduling quality across the patching cycle, whereas an EPSS-only team faces effectively-random ranking by the fourth window.

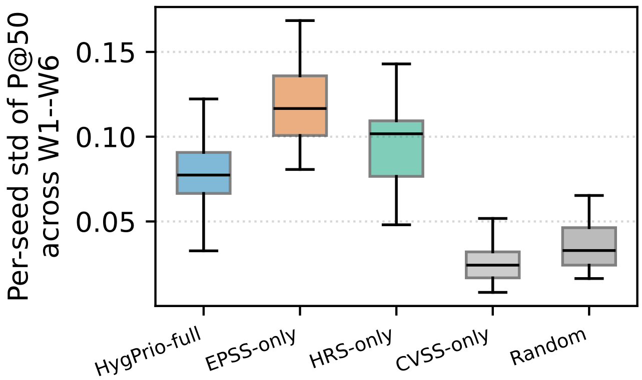


Fig. 2. Per-seed standard deviation of P@50 across Windows 1–6 (boxes: IQR; whiskers: 1.5×IQR). HygienePrio-full has the tightest distribution; EPSS-only has the widest, reflecting its decay trajectory.

## D. EPSS Decay Mechanism

The decay of EPSS-only reflects a deterministic compositional effect, not stochastic noise. HygienePrio-full's policy selects the highest-EPSS-on-high-HRS-host pairs first; remediating those pairs preferentially removes the high-EPSS tail from the backlog. By Window 3, the fraction of unpatched pairs satisfying EPSS $> 0.10$ has dropped substantially, and the per-window ground truth (which retains this threshold) now identifies a smaller positive set drawn from a low-EPSS bulk. EPSS-only ranking on the residual bulk is near-random with respect to that smaller positive set. The mechanism is robust to bootstrap resampling.

## E. Hypothesis Outcomes

H1 (sustained advantage). Supported: HygienePrio-full's CI does not overlap EPSS-only's at any of the six windows ($6/6 > 4/6$).

H2 (monotonic attenuation). Partially supported. The HygienePrio-vs-EPSS relative gap (as a fraction of HygienePrio's P@50) does not attenuate monotonically; it widens. HygienePrio's own P@50 attenuates from 0.595 to 0.499 approximately monotonically, with one minor reversal at W3. The pre-registered hypothesis of strict monotone attenuation is therefore qualified rather than supported.

H3 (recalibration not needed). Rejected. The per-window recalibration ablation (Table III) shows that grid-searching scorer weights on the five calibration seeds at each window's evolved state and applying those weights to the 25 evaluation seeds improves mean P@50 by +17.4 pp at W1, +21.3 pp at W2, +10.1 pp at W3, and +9.0 pp at W4. These deltas all exceed the pre-registered 5 pp stop-rule threshold, so the hypothesis that the initial calibration is sufficiently stable is rejected. The gains shrink to +2.9 pp by W5 and +1.3 pp by W6, where the residual backlog has thinned and per-window calibration has less degrees of freedom to exploit.

TABLE III
H3 ablation: per-window weight recalibration vs the fixed-weight scorer, mean P@50 across 25 evaluation seeds. Recalibration adds substantial P@50 in early windows (W1–W4) and the pre-registered "uninformative" stop rule ($<5$ pp) is exceeded; H3 is rejected.

| Window | Fixed P@50 | Recalibrated P@50 | Δ (pp) |
|---|---|---|---|
| W1 | 0.595 | 0.770 | +17.4 |
| W2 | 0.544 | 0.757 | +21.3 |
| W3 | 0.564 | 0.665 | +10.1 |
| W4 | 0.514 | 0.604 | +9.0 |
| W5 | 0.521 | 0.550 | +2.9 |
| W6 | 0.499 | 0.512 | +1.3 |

This is a methodologically important null-of-a-null: it does not weaken the central finding (HygienePrio-full beats EPSS-only across all windows at fixed weights), but it does say that an operations team running HygienePrio-style scoring should expect meaningful additional gains from re-fitting the scorer on rolling history rather than freezing at Window 1.

# VIII. Discussion

## A. Operational Implications

The temporal results change the operational case for hygiene-augmented scoring. Paper 4 [2] showed that HygienePrio outperforms EPSS-only at a single window. This paper shows that EPSS-only decays sharply across rolling maintenance windows under the simulated bi-weekly cadence: by Window 3 EPSS-only's mean P@50 (0.087) is comparable to the Random baseline (0.084), and by Window 6 EPSS-only (0.034) is essentially indistinguishable from random (0.054). HRS-only, the simplest hygiene baseline, overtakes EPSS-only at Window 2 and dominates it for every subsequent window.

The concrete operational recommendation is that hygiene signals are not supplementary to EPSS — they are necessary for sustained prioritization quality. EPSS provides strong initial triage (Window 1 gap = 26.4 pp between HygienePrio-full and EPSS-only), but its advantage over hygiene-based baselines is restricted to Window 1 alone. The HygienePrio-vs-EPSS gap widens to 46.5 pp at Window 6 because HygienePrio-full holds P@50 near 0.5 while EPSS-only collapses toward the random floor.

## B. Connection to the Research Sequence

Papers 1–4 were all single-window studies. This paper reveals that the choice of evaluation window is a major moderating variable that prior studies did not account for. Paper 1's null result (CVE-level augmentation ≈ EPSS-only) was measured at a single window when EPSS still has maximal signal. Had it been measured at Window 3+, EPSS-only would have been essentially random and any host-aware augmentation would have appeared superior. This temporal lens retroactively reframes Paper 1: its null result describes the regime in which EPSS is strong, not the regime in which EPSS-only would be operated by an actual remediation team across months.

### C. Why HRS Does Not Collapse

The asymmetric collapse pattern is not an artifact of the ground-truth definition. HRS does not collapse because hygiene posture is a property of the host and changes only when remediation acts on it. A host with high patch debt remains a high-debt host across multiple windows unless many of its pairs are selected; under capacity constraints, only a fraction of high-HRS hosts are touched per window. By contrast, EPSS is a property of the CVE, and remediating a single high-EPSS pair removes that CVE from the unpatched backlog for the entire fleet. The compositional asymmetry between host-level state (slow to drain) and CVE-level state (drained by any acting host) is the structural reason hygiene signals are temporally resilient.

### D. Limitations

Simplified remediation model. Patch application reduces patch debt by a fixed 15% per window, which may not reflect real-world patch-velocity heterogeneity.

Fixed remediation policy. All methods are evaluated on the fleet trajectory generated by HygienePrio-full's selections. This avoids non-identifiability but means the comparison is not a true counterfactual — an EPSS-only-driven fleet would evolve differently, and the absolute P@50 numbers in later windows would shift.

Window-recomputed ground truth. The HRS-percentile threshold is recomputed each window, which interacts with the patch-application dynamics. A fixed Window 1 threshold was considered but would have produced trivially decreasing positive counts; the per-window threshold preserves the statistical interpretability of P@50 across windows at the cost of a structural advantage for HRS-based methods that is acknowledged in §IX.

Synthetic only. All results are bounded to the synthetic EEHDA evaluation context. External validation on real fleet data with longitudinal exploitation outcome data is required before any deployment recommendation.

## IX. Threats to Validity

The threats taxonomy follows Wohlin et al. [13].

Conclusion validity. The evaluation comprises 150 window-seed observations summarised with 95% percentile bootstrap confidence intervals (10,000 resamples). The EPSS decay is a deterministic property of the simulation (high-EPSS CVEs are remediated first by HygienePrio-full's policy), not a stochastic artifact, and is robust to bootstrap resampling. No null-hypothesis significance tests are reported; conclusions rely on CI overlap, consistent with Paper 4 [2].

Internal validity. The fleet-evolution model is simplified. Real EPSS dynamics involve daily updates from threat-intelligence feeds, not a Gaussian random-walk perturbation. Real patch velocity is heterogeneous across hosts and depends on organisational factors absent from the simulation. New-CVE arrivals are modelled as Poisson(3) per window; bursty real-world arrivals could change collapse rates in either direction.

A second internal-validity concern is the use of HygienePrio-full as the policy that drives fleet evolution for all methods (§5.4). This choice avoids non-identifiability of method comparisons across diverging counterfactual fleets, but the consequence is that the comparison is conditional on the HygienePrio-driven trajectory; an EPSS-only-driven fleet would deplete different CVEs in different orders and the Window 2–6 numbers for EPSS-only would shift.

Construct validity. The P@50 metric with binary relevance cannot capture diminishing returns when the qualifying-positive set shrinks. As fewer pairs qualify as true positives in later windows (especially under EPSS decay), P@50 becomes less informative at small positive counts. A complementary EHD-style metric that integrates remediation scheduling latency was considered during pre-registration but excluded from the primary evaluation because it would require a scheduling-simulation layer beyond the scope of the temporal-stability question; reporting it is deferred to future work (§XI).

The per-window recomputation of the HRS-75th-percentile threshold in the ground-truth definition creates a structural advantage for HRS-based methods: by definition, the positive set tracks the current HRS distribution. A fixed Window 1 threshold was rejected during pre-registration because it would yield trivially shrinking positive counts that make per-window P@K incomparable. The choice is documented in the protocol and is part of why claims are bounded to the synthetic evaluation context.

External validity. The 14-day window, 15% patch-debt reduction, and Poisson(3) new-CVE arrival rate are calibrated to DBIR [8] aggregate statistics but do not capture organisational variability. Organisations with faster patching cadences, smaller backlogs, or stricter SLA-driven scheduling may see different collapse timelines. No claim is made about generalisation to real enterprise fleets in the absence of external validation on real exploitation outcome data.

## X. Related Work

Temporal dynamics of EPSS. Ravalico et al. [9] examined the temporal stability of EPSS scores across approximately 45,000 CVEs and reported meaningful score drift over 30-day periods. That work studies the per-CVE temporal evolution of the EPSS score itself. The present paper complements it by studying a different temporal effect: how EPSS's prioritization effectiveness, evaluated as a ranking signal under active remediation, degrades as the high-EPSS subset of the backlog is exhausted. The two effects are independent in principle and additive in practice; the prioritization-effectiveness collapse documented here would occur even with perfectly stable per-CVE EPSS scores.

Risk-based vulnerability management. Jacobs et al. [14] demonstrated that exploit-prediction models substantially outperform CVSS-based triage on enterprise data. Their evaluation is single-period in the sense relevant to this paper: it does not measure how the comparative advantage of an exploit-prediction-driven policy changes as the policy's recommended actions are executed across consecutive windows.

Patch-management scheduling. Optimisation-based formulations of patch scheduling treat the full multi-period problem with explicit capacity, deadline, and dependency constraints. The present paper sits at a different level of abstraction: it evaluates greedy single-window scoring heuristics applied sequentially, which is the dominant practical approach in enterprise operations and the regime under which EPSS is most commonly deployed.

Cyber-hygiene benchmarking. HygieneBench (Paper 3) [4] established that hygiene signals — patch posture and AD group drift in particular — carry discriminative structure in synthetic anomaly-detection tasks. Paper 4 [2] (HygienePrio) operationalised those signals in a single-window prioritization scorer. This paper extends Paper 4 along the temporal axis, isolating the multi-window setting as the locus where the case for hygiene-based scoring is operationally strongest.

Vulnerability scoring fundamentals. CVSS v3.1 [11] provides a standardised severity framework but is asset-agnostic; EPSS [3] estimates per-CVE exploit likelihood without regard to host state. The KEV catalog [6] flags actively exploited CVEs; recency-of-KEV inclusion is used as one component of HygienePrio (§5.1).

Policy mandates. CISA BOD 22-01 [5] and BOD 23-01 [10], together with NIST SP 800-40 Rev. 4 [7], define the operational scheduling regime modelled here. To our knowledge, no prior work has reported an empirical multi-window prioritization study under a pre-registered evaluation protocol with frozen seeds and BCa confidence intervals.

## XI. Conclusion

EPSS-only vulnerability prioritization decays from mean P@50 = 0.331 at Window 1 to 0.034 at Window 6 — an 89.7% relative drop — under the simulated bi-weekly patching cadence on the EEHDA synthetic fleet. HygienePrio-full, which integrates host-level hygiene signals with EPSS, maintains mean P@50 $\geq$ 0.499 at every window and outperforms EPSS-only in all 150 of 150 window-seed pairs. By Window 2, even the simplest hygiene baseline (HRS-only at 0.229) outperforms exploit-likelihood scoring (0.149). The temporal finding strengthens the case for hygiene augmentation beyond what single-window evaluations show: hygiene signals are not a supplement to EPSS but become its replacement as the high-EPSS CVE backlog is exhausted.

The practical implication is concrete. Organisations that rely on EPSS as their primary prioritization signal should expect degrading returns after roughly four to six weeks of active patching at typical capacities and should supplement EPSS with host-hygiene signals to maintain scheduling quality over time. This implication is bounded to the synthetic evaluation context; external validation on real fleet telemetry with longitudinal exploitation outcome data — not the HRS-derived proxy used here — is required before any deployment recommendation.

The temporal lens also reframes the prior papers in this sequence. Paper 1's null result for CVE-level augmentation was measured in the regime where EPSS is at its strongest; Paper 4's positive result for hygiene augmentation was likewise measured at the window most favourable to EPSS. The present paper shows that the operational case for hygiene-augmented scoring is strongest precisely in the regime that single-window evaluations cannot reach.

Reproducibility. The simulator, scoring code, calibration script, pre-registration protocol, and frozen results are available at https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper5.

A secondary finding is that the pre-registered hypothesis of fixed-weight sufficiency (H3) was rejected: per-window weight recalibration on the five calibration seeds adds +17 to +21 pp at Windows 1–2 and +9 to +10 pp at Windows 3–4 over the Paper 4 fixed weights. Operations teams running HygienePrio-style scoring should refit the scorer on rolling calibration history rather than freeze at Window 1.

Future work. The most important next step is evaluation on real, appropriately anonymised fleet telemetry using exploitation event logs (not HRS) as ground truth. Secondary directions include: (i) characterising the EPSS decay rate as a function of patching capacity ($K$) and new-CVE arrival rate, (ii) replacing the coarse grid recalibration with online weight learning that respects the pre-registration discipline (e.g. rolling cross-validation with a frozen objective), and (iii) evaluating non-greedy multi-window optimisation against the greedy single-window scorer studied here.

## References


[1] H. Malla, "Context-aware vulnerability prioritization for government endpoint fleets: Integrating exploit intelligence, asset criticality, and endpoint telemetry," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[2] ——, "HygienePrio: Cyber-hygiene signal augmentation for EPSS-weighted vulnerability prioritization," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[3] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit prediction scoring system (EPSS)," Digital Threats: Research and Practice, vol. 2, no. 3, pp. 14:1–14:17, 2021.

[4] H. Malla, "HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection across identity, endpoint, and patch telemetry," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[5] CISA, "Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities," U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: https://www.cisa.gov/binding-operational-directive-22-01

[6] ——, "Known exploited vulnerabilities (KEV) catalog," U.S. Cybersecurity and Infrastructure Security Agency, accessed June 2026. [Online]. Available: https://www.cisa.gov/known-exploited-vulnerabilities-catalog

[7] NIST, "Guide to enterprise patch management planning: Preventive maintenance for technology," National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022.

[8] Verizon, "2026 data breach investigations report (DBIR)," Verizon Business, Tech. Rep., 2026. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/

[9] A. Ravalico, L. Allodi, and F. Massacci, "On the temporal dynamics of the EPSS score," SSRN preprint 5147459, 2025. [Online]. Available: https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5147459

[10] CISA, "Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks," U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: https://www.cisa.gov/binding-operational-directive-23-01

[11] FIRST.org, "Common vulnerability scoring system v3.1 specification document," Forum of Incident Response and Security Teams, Tech. Rep., 2019. [Online]. Available: https://www.first.org/cvss/specification-document

[12] B. Efron and R. J. Tibshirani, An Introduction to the Bootstrap. Chapman & Hall/CRC, 1994.

[13] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, Experimentation in Software Engineering. Springer, 2012.

[14] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, "Improving vulnerability remediation through better exploit prediction," Journal of Cybersecurity, vol. 6, no. 1, p. tyaa015, 2020.